

The assessment identified OpenSSH 6.6.1p1 on TCP port 22 and Apache httpd 2.4.7 on TCP port 80. Nmap's Vulners script associated both software versions with vulnerability references, including findings with reported CVSS scores of 10.0.

For risk-management purposes, the two highest-priority findings were selected as **Critical Risk 1: OpenSSH exposure** and **Critical Risk 2: Apache web-server exposure**. The critical classification is based on the highest severity scores reported by the vulnerability scanner and the potential impact of remotely exposed services.

Critical Risk #1 — OpenSSH Vulnerability Exposure

Risk identification

Asset: scanme.nmap.org

IP: 45.33.32.156

Service: SSH

Port: [22/tcp](https://45.33.32.156:22)

Detected version: OpenSSH 6.6.1p1 Ubuntu

Nmap identified OpenSSH 6.6.1p1 running on TCP port 22 and returned multiple vulnerability references through the Vulners script. The terminal output includes CVE-2023-38408 and CVE-2016-1908 with reported scores of 9.8, as well as other entries with scores of 10.0.

Risk explanation

SSH is a remotely accessible administrative service. If a vulnerability associated with the detected OpenSSH version is applicable and exploitable, an attacker could potentially compromise the service or gain unauthorized access to the underlying system.

The risk is elevated because the service is exposed through a network-accessible port.

Risk classification

Risk level: Critical

Justification: The Nmap/Vulners output includes vulnerability references with scores up to **10.0**, while the service is remotely accessible through TCP port 22.

Treatment

Risk treatment: Mitigate

The preferred treatment is to reduce the risk by updating the affected software and restricting unnecessary remote access.

Basic mitigation steps

1. Verify which OpenSSH vulnerabilities actually apply to the installed version.
2. Upgrade OpenSSH to a supported and appropriately patched version.
3. Disable unnecessary SSH access.
4. Restrict SSH access using firewall rules or network ACLs.
5. Require strong authentication.
6. Monitor authentication attempts and SSH-related security events.
7. Perform another vulnerability scan after remediation.

Residual risk

After patching and restricting access, the risk should be rescanned. If the vulnerabilities are no longer detected and SSH access is appropriately restricted, the residual risk should be reduced.

Critical Risk #2 — Apache Web Server Vulnerability Exposure

Risk identification

Asset: scanme.nmap.org

IP: 45.33.32.156

Service: HTTP

Port: 80/tcp

Detected version: Apache httpd 2.4.7 (Ubuntu)

Nmap identified Apache httpd 2.4.7 running on TCP port 80. The Vulners results associated this version with numerous vulnerability references, including one reported at **10.0** and multiple entries reported at **9.8**.

Risk explanation

A publicly accessible web server represents an important attack surface. If vulnerabilities associated with the detected Apache version are applicable, an attacker could potentially exploit the web service to compromise confidentiality, integrity, or availability.

The vulnerability scan also identified a possible CSRF condition involving two search forms and reported `/images/` as a potentially interesting directory with listing.

Risk classification

Risk level: Critical

Justification: The vulnerability scanner associated Apache 2.4.7 with vulnerability references having reported scores as high as **10.0**. The service is also exposed through TCP port 80.

Treatment

Risk treatment: Mitigate

Basic mitigation steps

1. Verify the applicable Apache vulnerability references.
2. Upgrade Apache to a supported and patched release.
3. Remove unnecessary Apache modules and services.
4. Review web-server configuration.
5. Disable unnecessary directory listing.
6. Review web forms for appropriate CSRF protection.
7. Perform another vulnerability scan after remediation.
8. Continue monitoring the web server for suspicious activity.

Residual risk

After Apache is patched and its configuration is hardened, conduct another Nmap vulnerability scan. Any remaining findings should be reviewed and either remediated or formally accepted with documented justification.

Risk Priority Table

You can include this table directly in your assignment.

Risk ID	Risk	Asset	Severity	Treatment
R-001	Potential OpenSSH vulnerabilities	TCP/22 OpenSSH 6.6.1p1	Critical	Mitigate
R-002	Potential Apache vulnerabilities	TCP/80 Apache 2.4.7	Critical	Mitigate
R-003	Possible CSRF	Web search forms	Medium / Pending validation	Mitigate
R-004	Potential <code>/images/</code> directory exposure	Web server	Low–Medium / Pending validation	Mitigate

The CSRF finding came from Nmap's `http-csrf` script, which identified two search forms on the site's root page. The `http-enum` script also identified `/images/` as a potentially interesting directory with listing.

Risk Monitoring Procedure

Risk Monitoring Procedure — Nmap Vulnerability Monitoring

Purpose:

Monitor previously identified risks and determine whether remediation has reduced the organization's exposure.

Step 1 — Maintain a risk register

Create a simple spreadsheet containing:

Risk ID	Asset	Finding	Severity	Status	Date Identified	Next Review
R-001	scanme.nmap.org	OpenSSH vulnerabilities	Critical	Open	Assessment date	30 days
R-002	scanme.nmap.org	Apache vulnerabilities	Critical	Open	Assessment date	30 days
R-003	scanme.nmap.org	Possible CSRF	Pending	Open	Assessment date	30 days
R-004	scanme.nmap.org	/images/ exposure	Pending	Open	Assessment date	30 days

Step 2 — Perform periodic Nmap scans

Run a service/version scan:

```
nmap -sV scanme.nmap.org
```

Then run the vulnerability assessment:

```
nmap -sV --script vuln scanme.nmap.org
```

Save the results:

```
nmap -sV --script vuln scanme.nmap.org -oN risk-monitoring-scan.txt
```

Step 3 — Compare results

Compare the new scan against the previous assessment.

For example:

Previous scan:

OpenSSH 6.6.1p1

Potential vulnerabilities detected

New scan:

OpenSSH [new version]

Previous vulnerability references no longer detected

The risk can then move from:

Open → Remediated → Closed

if the organization has sufficient evidence that the underlying issue has been addressed.

Step 4 — Track unresolved risks

If a vulnerability remains, keep it in the risk register.

Example:

R-001 remains open because the vulnerable software version remains exposed and remediation has not yet been completed.

Step 5 — Escalate critical risks

Critical findings should be prioritized for remediation and reviewed by the appropriate system/security administrator.

Step 6 — Reassess after remediation

After applying patches or configuration changes, repeat the Nmap assessment.

The risk should only be marked **Closed** after the organization has evidence that the vulnerability or exposure has been addressed.

Justification for Risk Decisions

The two highest-priority risks were selected based on the Nmap vulnerability scan results. OpenSSH 6.6.1p1 and Apache httpd 2.4.7 were both exposed through network-accessible services, and the Vulners NSE output associated these versions with vulnerability references having reported severity scores as high as 10.0.

Mitigation was selected as the preferred treatment because the identified risks involve software versions and exposed services that can potentially be reduced through patching, configuration changes, and access restrictions. The findings are considered potential risks rather than confirmed exploitable vulnerabilities because Nmap's version and CPE matching does not independently establish that every listed vulnerability applies to the target.

Therefore, validation and follow-up scanning are included as part of the risk-management process.

A recurring monitoring procedure was selected because vulnerabilities can reappear or remain unresolved after an initial assessment. Periodic scanning and comparison against previous results provides evidence that remediation has been effective.